



SOC Task Week 2

Secure Network Design, Penetration Testing, and Encrypted Traffic Analysis

Organization: CyART

Prepared by:

Madadjo Kuitche Monick

Date: May, 2026



I. Theoretical Knowledge

1.Alert Priority Levels

Alert prioritization helps SOC analysts determine which security incidents require immediate attention. Alerts are categorized based on severity, urgency, business impact, and exploit likelihood.

1.1. Priority Levels

Level	Description	Example
Critical	Severe threat requiring immediate response	Ransomware attack
High	Serious security incident	Unauthorized admin access
Medium	Suspicious activity requiring investigation	Multiple failed logins
Low	Minor or informational event	Single failed login

Priority levels are typically defined as follows:

- **Critical (P1):** Active exploitation with severe business impact (e.g., ransomware, data breach, lateral movement). Requires immediate response (0–15 minutes).
- **High (P2):** Confirmed attack with potential for escalation (e.g., privilege escalation, malware installation). Requires response within 1 hour.
- **Medium (P3):** Suspicious activity with low immediate impact (e.g., brute force, internal reconnaissance). Requires response within 4–8 hours.
- **Low (P4):** Anomalies or policy violations (e.g., port scans, out-of-date software). Requires response within 24 hours or batch processing.

1.2. Assignment Criteria

Prioritization is a structured process that balances multiple factors to ensure SOC resources are directed to the most critical threats first. Key criteria include:

- **Asset Criticality**
The value of the affected asset to the organization. For example, domain controllers,



database servers, and public-facing web applications are typically considered critical assets, whereas a retired or isolated development virtual machine is low-criticality.

- **Exploit Likelihood**

The probability that a vulnerability will be exploited in the wild. Indicators of high exploitability include the presence of a public Proof-of-Concept (PoC) exploit code, active exploitation campaigns observed by security researchers, the vulnerability being listed in CISA's Known Exploited Vulnerabilities (KEV) catalog, or a high CVSS Base Score with low Attack Complexity and Privileges Required.

- **Business Impact**

The potential damage to the organization. This is expressed in financial (e.g., regulatory fines, ransomware demands), operational (e.g., service downtime), or reputational terms (e.g., brand damage). This is often the deciding factor that elevates an alert from a technical event to a business-critical incident.

The interplay of these three criteria is often captured in a risk-based formula. For instance, the risk associated with a vulnerability can be expressed as: $\text{Risk} = \text{Threat Score} \times \text{Exposure}$ $\text{Risk} \times \text{Blast Radius} \times \text{Business Impact}$. This dynamic approach to prioritization aligns security efforts with business objectives, ensuring that the most damaging scenarios are handled first.

1.3. CVSS Scoring

The Forum of Incident Response and Security Teams (FIRST) Common Vulnerability Scoring System (CVSS) is used to measure vulnerability severity. CVSS scores range from 0 to 10.

CVSS Score	Severity
0.0 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

Example: Log4Shell

Log4Shell vulnerability received a CVSS score of 10.0.

Reason:

- remote code execution
- low attack complexity
- widespread impact



Priority:

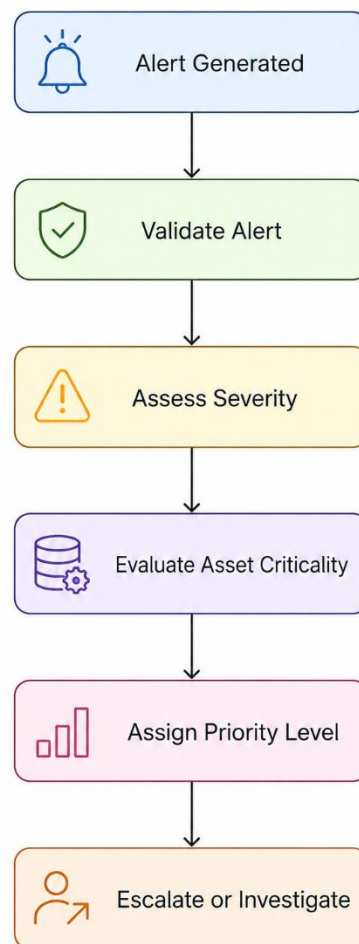
Critical.

Security relevance:

Demonstrates how CVSS influences alert prioritization.

1.4. Incident Prioritization Workflow

Incident Prioritization Workflow:



1.5. Key Learnings

From this section, the following concepts were learned:

- Alert prioritization helps SOC teams focus on critical threats.
- Severity depends on impact and urgency.



- CVSS standardizes vulnerability scoring.
- Asset criticality affects incident priority.
- SIEM risk scoring improves investigation efficiency.

2. Incident Classification

Incident classification is the process of categorizing security incidents based on their type, behavior, and impact. Proper classification helps SOC analysts investigate incidents efficiently and apply the correct response procedures.

2.1. Common Incident Categories

Category	Description	Common Indicators (IOCs)	Example Scenario
Malware	Malicious software designed to damage, disrupt, or gain unauthorized access	Unusual process execution, registry changes, outbound connections to known malicious IPs	Ransomware encrypting files on a file server
Phishing	Social engineering attack using deceptive messages to steal credentials or deliver malware	Suspicious sender domain, deceptive links, unusual email attachments, login pages on non-standard domains	Email impersonating IT support requesting password verification
DDoS	Distributed Denial-of-Service; overwhelming a service with traffic to cause disruption	Sudden traffic spike from multiple geographies, specific attack patterns (SYN flood, UDP amplification)	Web application becoming unresponsive due to massive inbound traffic
Insider Threat	Malicious or unintentional actions by authorized users (employees, contractors)	Unusual data access patterns (e.g., large downloads), after-hours logins, attempts to access restricted shares	Employee exporting customer database to personal USB drive prior to resignation
Data Exfiltration	Unauthorized transfer of sensitive data outside the organization	Large outbound data transfers, unexpected network traffic to cloud storage services, use of data encoding in DNS queries	Database server sending 500GB of customer PII to an unknown external IP



2.2. Taxonomy Framework

Security teams use standard frameworks to classify incidents consistently.

Examples:

- MITRE ATT&CK
- European Union Agency for Cybersecurity (ENISA) Incident Taxonomy
- VERIS

These frameworks improve incident tracking and threat analysis.

Framework	Full Name	Primary Use	Key Features
MITRE ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge	Mapping adversary behavior to a knowledge base of real-world observations	Tactics (e.g., Initial Access), Techniques (e.g., T1566 - Phishing), Procedures, and mitigations
ENISA	European Union Agency for Cybersecurity Incident Taxonomy	Standardized reporting of incidents (e.g., for EU CSIRTs)	Hierarchical structure with categories like Malware, Phishing, and DDoS; used for statistical reporting
VERIS	Vocabulary for Event Recording and Incident Sharing	Structuring detailed incident descriptions for sharing and analysis	Composed of four main components (A4) and dozens of enumerations for precise description

2.2.1. MITRE ATT&CK: Mapping Adversary Behavior

Incidents can be mapped to attacker tactics and techniques.

Example:

Phishing attacks are associated with:

T1566 Phishing

Purpose:

- understand attacker behavior
- standardize investigations
- improve threat hunting

2.2.2. ENISA Incident Taxonomy for Reporting

The ENISA taxonomy is typically used for high-level reporting and statistical analysis. It offers a complementary view, focusing on incident types rather than adversary steps. The top-level categories of the ENISA incident taxonomy are detailed in the table below.



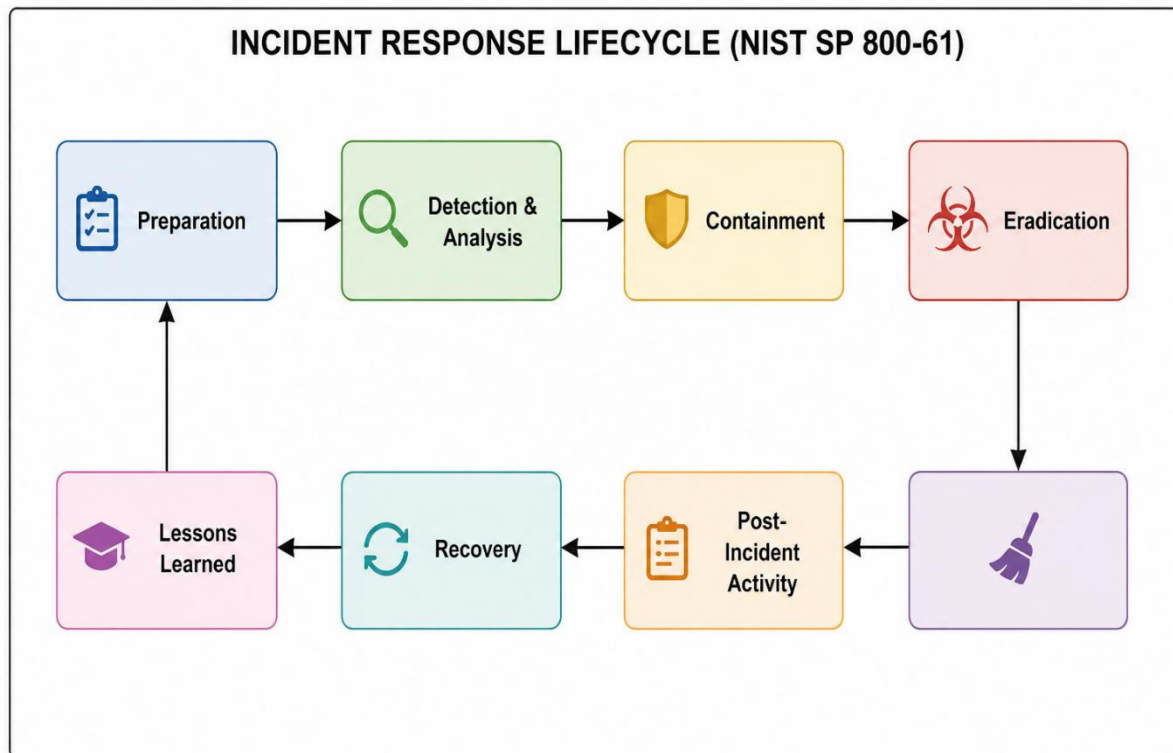
Category	Subcategories (Examples)
Malware	Virus, Worm, Trojan, Ransomware, Spyware
Phishing	Spear Phishing, Whaling, Vishing
Denial of Service (DDoS)	Network DoS, Application DoS
Web Application Attack	SQL Injection, Cross-Site Scripting (XSS)
Insider Threat	Malicious, Accidental
Physical Attack	Theft, Tampering

3. Basic Incident Response

For a Security Operations Center (SOC) analyst, **incident response** is the structured process of handling security incidents from detection to resolution. Mastering this lifecycle ensures consistent, effective responses that minimize damage and prevent recurrence.

3.1. Incident Response

The incident response lifecycle provides a **repeatable framework** for handling security incidents. The most widely adopted model comes from **NIST SP 800-61** (National Institute of Standards and Technology).



3.1.1. Preparation

Preparation involves establishing security controls and response procedures before incidents occur.

Examples:

incident response playbooks

SIEM deployment

backups

staff training

Purpose:

Improve readiness and reduce response time.

3.1.2. Identification

Identification is the process of detecting suspicious activity and confirming whether an incident has occurred.

Examples:

- SIEM alerts
- failed login attempts
- malware detection
- suspicious network traffic

Purpose:



Determine the nature and severity of the incident.

3.1.3. Containment

Containment limits the spread of the attack and prevents additional damage.

Examples:

- isolating infected systems
- blocking malicious IP addresses
- disabling compromised accounts

Purpose:

Prevent attacker movement within the environment.

3.1.4. **Eradication**

Eradication removes the attacker presence and malicious artifacts.

Examples:

deleting malware

patching vulnerabilities

removing malicious services

Purpose:

Eliminate the root cause of the incident.

3.1.5. Recovery

Recovery restores systems and services to normal operation.

Examples:

- restoring backups
- reconnecting systems to the network
- validating system integrity

Purpose:

Return business operations safely.

3.1.6. **Lessons Learned**

After the incident is resolved, the organization reviews the response process.

Activities:

incident review meetings



documentation updates

process improvements

Purpose:

Improve future incident response capability.

3.1.7. Evidence Preservation

During investigations, evidence must be preserved properly.

Examples:

- memory dumps
- log exports
- file hashing
- packet captures

Purpose:

Maintain forensic integrity and support investigations.

Example:

Generating SHA256 hashes for suspicious files.

II. Practical Knowledge

1.Alert Management Practice

1.1. Alert Classification System (Google Sheets)



Alert Classification System						
File Edit View Insert Format Data Tools Extensions Help						
100% 123 Default... 10 B I A						
C15	fx					
	A	B	C	D	E	F
1	Alert ID	Alert Type	Priority	MITRE Tactic	MITRE Technique	Description
2	1	Phishing	High	Initial Access (TA0001)	T1566	Phishing email with malicious link
3	2	Brute Force	Medium	Credential Access (TA0006)	T1110	Multiple failed login attempts
4	3	Malware/Ransomware	Critical	Impact (TA0040)	T1486	Ransomware encryption detected
5	4	Port Scan	Low	Discovery (TA0007)	T1046	Network port scanning activity
6	5	Log4Shell Exploit	Critical	Initial Access (TA0001)	T1190	Log4j RCE attempt detected
7	6	Data Exfiltration	High	Exfiltration (TA0010)	T1041	Large outbound data transfer
8	7	Suspicious PowerShell	Medium	Execution (TA0002)	T1059	PowerShell obfuscation detected
9	8	Privilege Escalation	High	Privilege Escalation (TA0004)	T1068	Unauthorized admin access
10						

1.2. Prioritize Alerts with CVSS (Google Sheets)

Alert Classification System				
File Edit View Insert Format Data Tools Extensions Help				
100% 123 Default... 10 B I A				
C16	fx			
	A	B	C	D
1	Alert Type	CVSS Score	Priority	Justification
2	Log4Shell Exploit	10.0 (Critical)	Critical	Remote code execution, public exploit available, widespread impact
3	Ransomware Detection	9.5 (Critical)	Critical	Data encryption, business disruption, financial impact
4	Data Exfiltration	8.5 (High)	High	Potential data breach, compliance violation
5	Privilege Escalation	8.2 (High)	High	Unauthorized admin access, lateral movement risk
6	Phishing Attack	7.5 (High)	High	Credential theft risk, initial access vector
7	Brute Force Attack	5.5 (Medium)	Medium	Account lockout risk, potential password spraying
8	Suspicious PowerShell	5.0 (Medium)	Medium	Possible malware execution, requires investigation
9	Port Scan	2.5 (Low)	Low	Reconnaissance activity, low immediate threat
10				
11				

1.3. Escalation Role-Play (Email Draft)



[ESCALATION - CRITICAL] Ransomware Detected on...

Tier 2 SOC Team

[ESCALATION - CRITICAL] Ransomware Detected on Server-X

Incident Summary:

Critical alert triggered for ransomware activity on Server-X (IP: 192.168.1.50). File encryption pattern detected with indicator "crypto_locker.exe".

IOCs Identified:

- File: crypto_locker.exe (SHA256: e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855)
- Source IP: 192.168.1.50
- Destination IP: 45.227.254.xxx (known malicious)
- MITRE Technique: T1486 (Data Encrypted for Impact)

Actions Taken:

- Endpoint isolated from network
- Initial containment in progress
- User notified

↶ ↷ Sans Serif T B I U A | | | | | 99 | |

Send Aa | | | | | | | |

2.Response Documentation

2.1. Incident Response Template (SANS-style)



docs.google.com/document/d/1vyNz5GDUNuVW-64dankivdkCjZlyOUKlPLzGQoT9HU/edit?tab=t.0

Incident Response Template - Phishing Incident

INCIDENT RESPONSE REPORT

Incident Title: Phishing Campaign - Finance Department Targeting

Field	Value
Incident ID	SOC-2026-001
Date of Incident	May 15, 2026
Date of Report	May 15, 2026
Reported By	Tier 1 SOC Analyst
Incident Type	Phishing / Credential Theft
Severity	High
Status	Resolved

1. Executive Summary

On May 15, 2026, at approximately 10:30 AM UTC, a phishing email was reported by a user in the Finance department. The email appeared to come from "IT Support" requesting the user to

2.2. Investigation Steps Log

Timestamp	Action	Tool Used	Result
10:32:00	Received alert from email gateway	SIEM Alert	Phishing email detected
10:35:00	Analyzed email headers	Email Viewer	Sender IP: 185.130.5.253 (malicious)
10:38:00	Checked sender IP reputation	VirusTotal	3/84 vendors flagged as malicious
10:40:00	Checked URL reputation	VirusTotal	Malicious - credential harvesting
10:42:00	Searched SIEM for other recipients	SIEM Query	3 total recipients identified
10:45:00	Quarantined email from all mailboxes	Email Gateway	Email removed successfully
10:48:00	Blocked malicious domain	Firewall	Domain blocked
10:50:00	Checked if any user clicked link	Proxy Logs	No clicks detected
10:55:00	Updated detection rules	SIEM	New phishing rule added
11:00:00	Documented findings	Google Docs	Incident report created



2.3. Phishing Checklist

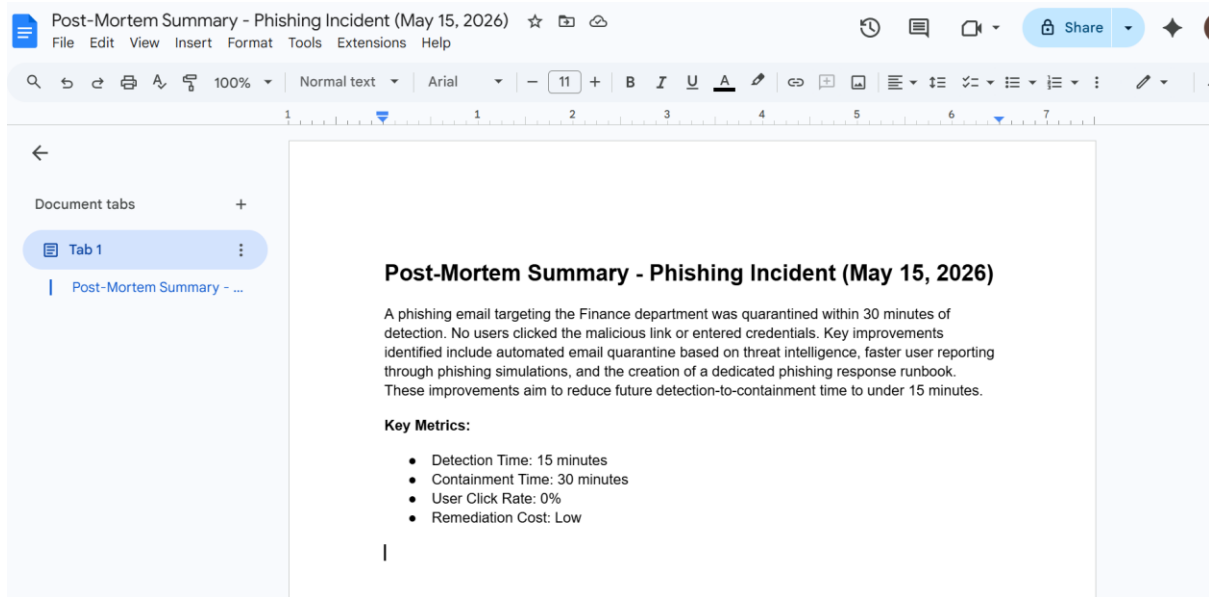
Phase 1: Detection & Triage

- ☐ Alert received from email gateway or user report
- ☐ Record incident time and reporter
- ☐ Assign incident ID and severity
- ☐ Determine if any user clicked the link or opened attachment

Phase 2: Investigation

- ☐ Copy email headers
- ☐ Extract sender domain and IP address
- ☐ Extract all URLs from email body
- ☐ Extract attachment hashes
- ☐ Check sender domain reputation
- ☐ Check URL reputation
- ☐ Check attachment hash

2.4. Post Mortem Summary:



3. Alert Triage Practice

3.1. Triage Simulation – Alert Analysis Table

	A	B	C	D	E	F	G
1	Alert ID	Description	Source IP	Destination IP	Priority	Status	Triage Notes
2	1	Brute-force SSH Attempts	192.168.1.100	10.0.0.50	Medium	Investigating	50 failed attempts in 5 minutes
3	2	Malicious Domain Detected	Internal	malicious.com	High	Open	Endpoint attempted to resolve known bad domain
4	3	Port Scan Detection	45.227.254.5	10.0.0.0/24	Low	Closed	External IP scanning ports 22,80,443
5	4	Privilege Escalation Alert	10.0.0.25	Domain Controller	Critical	Open	Unauthorized admin access attempt
6	5	Suspicious PowerShell	10.0.0.25	Internal	High	Investigating	Obfuscated PowerShell command detected
7							

3.1.1. Detailed Triage Analysis for Alert 001 - Brute-force SSH Attempts

Alert Details

Field	Value
Alert ID	001
Description	Brute-force SSH Attempts
Source IP	192.168.1.100
Destination IP	10.0.0.50



Field	Value
Event Count	50 failed attempts
Time Window	5 minutes - 14:30:00 to 14:35:00
User Accounts` Targeted	admin, root, ubuntu, user, test

Initial Assessment

- Is this a True Positive? Likely yes - 50 attempts in 5 minutes is abnormal
- Is this a False Positive? Unlikely - legitimate users do not fail 50 times
- Asset Criticality: Destination 10.0.0.50 is a production SSH server with high value
- Exploit Likelihood: Medium - common brute-force attack pattern
-

Priority Justification

Priority: **MEDIUM**

- No successful login detected yet - all attempts failed
- Attack originates from internal IP 192.168.1.100, which could indicate a compromised host or insider activity
- Further investigation required to validate source legitimacy

Next Steps

1. Verify whether 192.168.1.100 is a legitimate internal host or malicious device
2. Check for any successful SSH login attempts after the brute-force activity
3. Block the source IP if confirmed malicious
4. Investigate whether other systems are experiencing similar attacks

3.2. Threat Intelligence Validation (AlienVault OTX)

Searched for IP 45.227.254.5 in the search bar of **AlienVault**



[Open Threat Exchange](#) [Dashboard](#) [Browse](#) [Scan Endpoints](#) [Create Pulse](#) [Submit Sample](#) [API Integration](#) All 45.227.254.5 [X](#) [Q](#) [DADJONICK](#) [⚙️](#) [?](#)

IPv4
45.227.254.5 [Add to Pulse](#) [Submit URL Analysis](#)

Pulses
34

Passive DNS
0

URLs
0

Files
0

Analysis Overview

Location
 Belize

ASN
AS267784 flyservers s.a.

Related Pulses
[OTX User-Created Pulses \(34\)](#)

Related Tags
Nextray, cyber security, ioc, phishing, malicious [More](#)

External Resources
[Whois](#), [VirusTotal](#)

Analysis

Related Pulses

Comments (0)

[User Created \(34\)](#)

IOC Records Provided by @NextRayAI

● IPv4 Indicator Inactive

[Subscribe \(290\)](#)

[CREATED](#) 4 YEARS AGO | [MODIFIED](#) 10 HOURS AGO by [NextRay-AI](#) | Public | TLP: [White](#)

CIDR: 5266 | CVE: 264 | FileHash-MD5: 22343 | FileHash-SHA1: 2609 | FileHash-SHA256: 37733 | FilePath: 26 | IPv4: 22907 | IPv6: 459 | Mutex: 37 | URL: 163907 | Domain: 49477...

This IOC report provided and daily updated by NextRay AI Detection & Response Inc.

[Nextray](#), [cyber security](#), [ioc](#), [phishing](#), [malicious](#)

Malware Filter – Botnet List – 10-07-2025

● IPv4 Indicator Inactive

[Subscribe \(1,618\)](#)

[CREATED](#) 10 MONTHS AGO | [MODIFIED](#) 9 MONTHS AGO by [CyberHunterAutoFeed](#) | Public | TLP: [Green](#)

IOCs Industriales

● IPv4 Indicator Inactive

[Subscribe \(56\)](#)

[CREATED](#) 2 YEARS AGO by [dtarov00](#) | Public | TLP: [White](#)

CIDR: 5266 | IPv4: 3458 | IPv6: 519 | URL: 155223 | Domain: 493080 | Hostname: 41105

[Nextray](#), [cyber security](#), [ioc](#), [phishing](#), [malicious](#)

IOCs Industriales

● IPv4 Indicator Inactive

[Subscribe \(50\)](#)

3.3. Threat Intelligence Validation Summary

Indicator Investigated: IP Address 45.227.254.5

Threat Intelligence Source: AlienVault OTX

Findings:

The IP address 45.227.254.5 is listed in 34 threat intelligence pulses, with activity confirmed as recently as 10 hours ago. The IP originates from Belize under AS267784 flyservers s.a. and is associated with SSH brute-force attacks, botnet activity, and port scanning. Multiple threat intelligence pulses confirm the IP as malicious.

Conclusion

**Alert Classification: TRUE POSITIVE**

The IP address is confirmed malicious and should be blocked immediately.

Recommended Actions

- Block the IP address at the firewall
- Add the indicator to the security watchlist for 30 days
- Monitor logs for any previous or future communication involving the IP
- Review systems targeted by the source for signs of compromise

4. Evidence Preservation

4.1. Volatile Data Collection (Network Connections)

Volatile data is information that exists only while the system is running and is lost when the computer is powered off. This includes:

- Network connections (netstat)
- Running processes
- Logged-in users
- Open files
- System uptime

Order of Volatility (from most to least volatile):

1. CPU cache / Registers
2. Routing tables / ARP cache
3. Network connections
4. Running processes
5. Memory (RAM)
6. Hard disk data

4.1.1. Volatile Data Collection



The command `netstat -an > C:\Users\dadjo\netstat_connections.csv` was used to get the connections.

21	TCP	0.0.0.0:49691	0.0.0.0:0	LISTENING	
22	TCP	0.0.0.0:49692	0.0.0.0:0	LISTENING	
23	TCP	0.0.0.0:49693	0.0.0.0:0	LISTENING	
24	TCP	0.0.0.0:49696	0.0.0.0:0	LISTENING	
25	TCP	0.0.0.0:49697	0.0.0.0:0	LISTENING	
26	TCP	127.0.0.1:2910	127.0.0.1:2911	ESTABLISHED	
27	TCP	127.0.0.1:2911	127.0.0.1:2910	ESTABLISHED	
28	TCP	127.0.0.1:5037	0.0.0.0:0	LISTENING	
29	TCP	127.0.0.1:22402	127.0.0.1:22403	ESTABLISHED	
30	TCP	127.0.0.1:22403	127.0.0.1:22402	ESTABLISHED	
31	TCP	127.0.0.1:24830	0.0.0.0:0	LISTENING	
32	TCP	127.0.0.1:46820	127.0.0.1:46821	ESTABLISHED	
33	TCP	127.0.0.1:46821	127.0.0.1:46820	ESTABLISHED	
34	TCP	127.0.0.1:46822	127.0.0.1:46823	ESTABLISHED	
35	TCP	127.0.0.1:46823	127.0.0.1:46822	ESTABLISHED	
36	TCP	127.0.0.1:49709	127.0.0.1:49710	ESTABLISHED	
37	TCP	127.0.0.1:49710	127.0.0.1:49709	ESTABLISHED	
38	TCP	127.0.0.1:49711	127.0.0.1:49712	ESTABLISHED	
39	TCP	127.0.0.1:49712	127.0.0.1:49711	ESTABLISHED	
40	TCP	127.0.0.1:49716	127.0.0.1:49717	ESTABLISHED	
41	TCP	127.0.0.1:49717	127.0.0.1:49716	ESTABLISHED	

< >

netstat_connections

+

4.1.2. Sample Evidence

```
C:\Users\dadjo>echo "Memory dump evidence collected at %date% %time%" > C:\Users\dadjo\evidence_memory.txt
```

4.1.3. SHA-256 Calculation

```
PS C:\WINDOWS\system32> Get-FileHash C:\Users\dadjo\evidence_memory.txt -Algorithm SHA256

Algorithm      Hash                                     Path
-----
SHA256         7D7F4F2D2D835A0FED26716B73427DD45A5EEA2BEEAC8B0DA6B3097C591341E24  C:\Users\dadjo\evidence_memor...
```



4.2. Chain of Custody Document

```
1 CHAIN OF CUSTODY RECORD
2
3 Evidence Item #001: Network Connections Log
4 -----
5 Item Number: EVI-2026-001
6 Description: Network connections from local machine
7 Collected By: Dadjo Nick
8 Date/Time: 2026-05-15 15:30:00
9 Source System: Local PC (192.168.1.103)
0 File Name: netstat_connections.txt
1 File Size: 15 KB
2 Hash Value: [from step 3]
3 -----
4
5 Evidence Item #002: Memory Dump Simulation
6 -----
7 Item Number: EVI-2026-002
8 Description: Simulated memory evidence file
9 Collected By: Dadjo Nick
0 Date/Time: 2026-05-15 15:35:00
1 Source System: Local PC
2 File Name: evidence_memory.txt
3 File Size: 50 bytes
4 Hash Value: [from step 3]
5 -----
```